Introduction and Security Principles

CSE 405 - Lecture 1

Broad Objectives

- How to think adversarially about computer systems
- How to assess threats for their significance
- How to build computer systems with robust security properties
- How to gauge the protections and limitations provided by today's technology
- How attacks work in practice

- What mistakes *not to make!*

What is security?

What is security?

Enforcing a desired property *in the presence of an attacker*

data confidentiality

user privacy

data and computation integrity

authentication

availability

…

Why is security important?

- It is important for our
  - physical safety
  - confidentiality/privacy
  - functionality
  - protecting our assets
  - successful business
  - a country’s economy and safety
  - and so on…

Why is security important?

- Consider: Physical Safety

The Washington Post

Link

FBI probe of alleged plane hack sparks worries over flight safety

Drew Harwell *May 18, 2015*

PCWorld

Link

Pacemaker hack can kill via laptop

Jeremy Kirk *October 21, 2012*

Why is security important?

- Consider: Privacy/Confidentiality



Link

91 Percent of Healthcare Organizations Suffered Data Breaches in the Past Two Years

Jeff Goldman *May 12, 2015*



Link

Data Breach Tracker: All the Major Companies That Have Been Hacked

Karavbrandeisky *October 30, 2014*

In 2020, there were over 1001 breaches, affecting the data of 155,000,000 individuals

Why is security important?

- Consider: National security

THE WALL STREET JOURNAL.

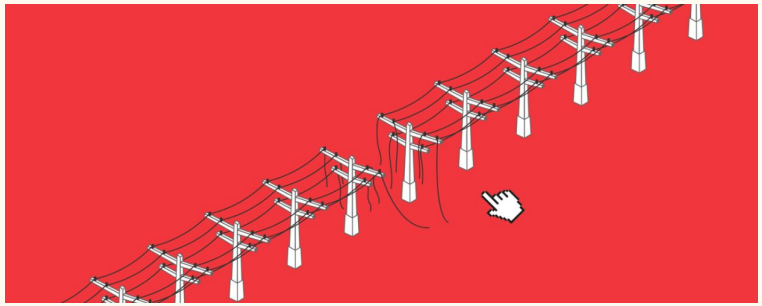
Link

America's Electric Grid Has a Vulnerable Back Door—and Russia Walked Through It

Rebecca Smith and Rob Barry

January 10, 2019

A Wall Street Journal reconstruction of the worst known hack into the nation's power system reveals attacks on hundreds of small contractors



What is hackable?

- Everything!
  - Especially things connected to the Internet
  - Assume that every system is a target
  - A casino was hacked because a fish-tank thermometer was hacked within the network

SLATE

Link

For the First Time, Hackers Have Used a Refrigerator to Attack Businesses

Julie Bort *January 17, 2014*

Hacking '❤️' to Track ANY WhatsApp or Signal User

https://www.youtube.com/watch?v=HHEQVXNCrW8

Security Principles

Textbook Chapter 1

Security Principles

- Security principles
  - Know your threat model
  - Consider human factors (Psychological acceptability)
  - Security is economics (Work factor)
  - Detect if you can’t prevent (Compromise recording)
  - Defense in depth
  - Least privilege
  - Separation of responsibility
  - Ensure complete mediation
  - Don’t rely on security through obscurity (Open design)
  - Use fail-safe defaults
  - Design in security from the start

Know Your Threat Model

Textbook Chapter 1.1 & 1.12

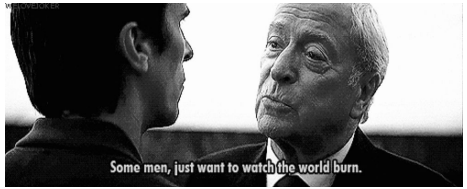
Security Principle: Know Your Threat Model

- **Threat model**: A model of who your attacker is and what resources they have
- It all comes down to people: The attackers
  - No attackers = No problem!
  - One of the best ways to counter an attacker is to attack their reasons
- Why do people attack systems?
  - Money
  - Politics
  - Retaliation
  - Fun, watching the world burn









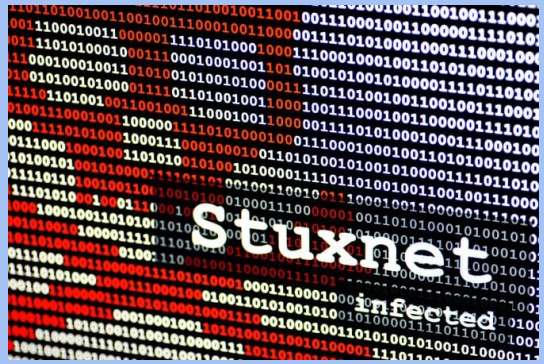
Security Principle: Know Your Threat Model

- Consider: Personal security
- Who and why might someone attack *you*?
  - Criminals might attack you for money
  - Teenagers might attack you for laughs or to win online games
  - Governments might spy on you to collect intelligence
  - Intimate partners might spy on you
    - This is a surprisingly dangerous threat model!

The National Security Agency (NSA)

- Stated purpose: To collect information to protect US national security
- Since its founding in 1952, the NSA has:
  - Decoded secret enemy communications in wars
  - Spied on people in the US and other countries (sometimes legally, sometimes illegally)
  - Participated in security research and helped develop security standards
  - Developed secret techniques for surveillance and cyberattacks
- For better or worse, the NSA are an essential part of computer security
  - We'll see many stories with the NSA this semester

https://en.wikipedia.org/wiki/Operation_Olympic_Games



Threat Model: Common Assumptions for Attackers

- Assume the attacker…
  - Can interact with systems without notice
  - Knows general information about systems (operating systems, vulnerabilities in software, usually patterns of activity, etc.)
  - Can get lucky
    - If an attack only succeeds 1/1,000,000 times, the attacker will try 1,000,000 times!
  - May coordinate complex attacks across different systems
  - Has the resources required to mount the attack
    - This can be tricky depending on who your threat model is
  - Can and will obtain privileges if possible

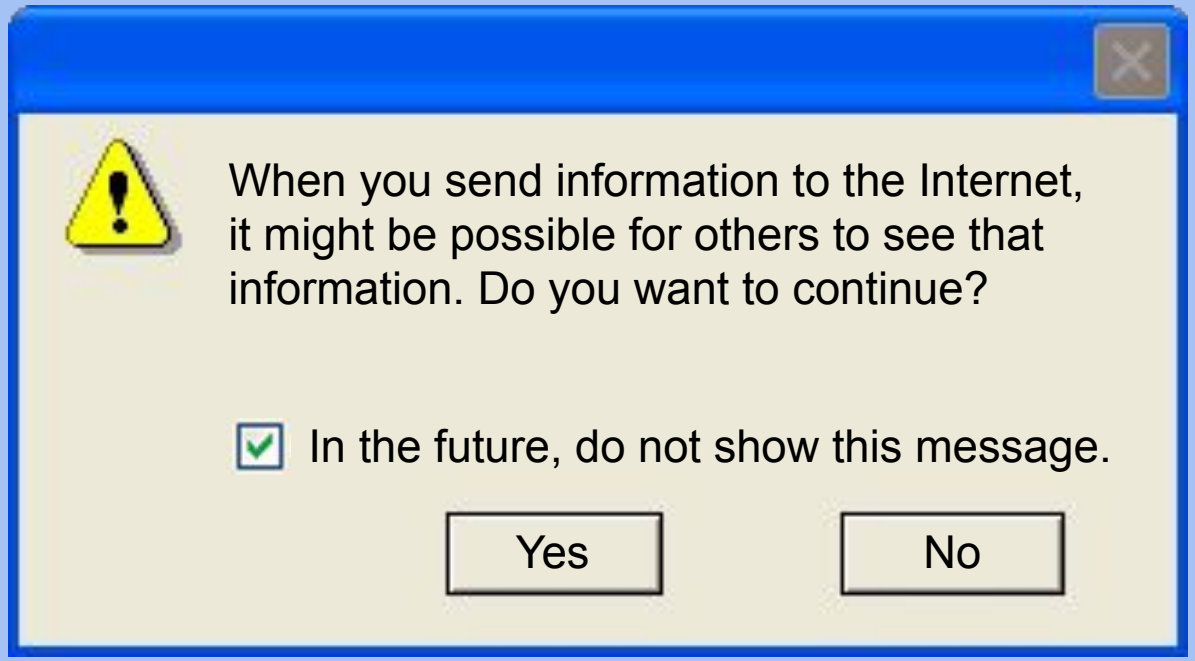
Trusted Computing Base

- **Trusted computing base (TCB)**: The components of a system that security relies upon
- Properties of the TCB:
  - Correctness
  - Completeness (can’t be bypassed)
  - Security (can’t be tampered with)
- Generally made to be as small as possible
  - A smaller, simpler TCB is easier to write and audit.
  - **KISS principle**: Keep It Simple, Stupid

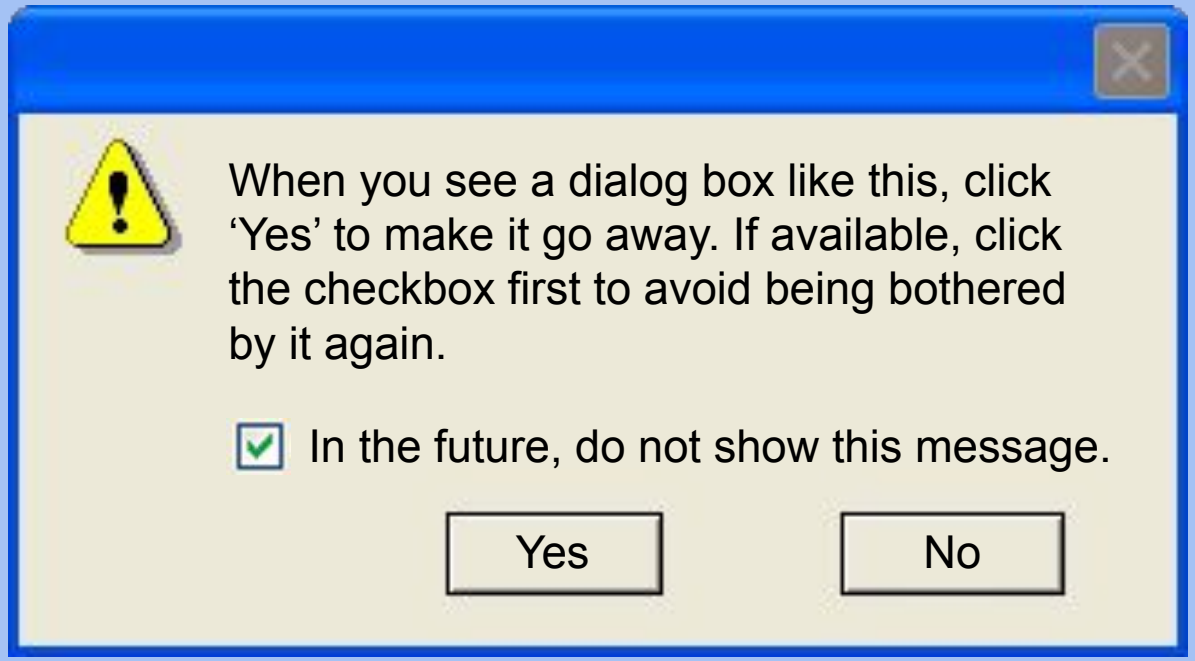
Consider Human Factors

Textbook Chapter 1.2

Warning Dialogs



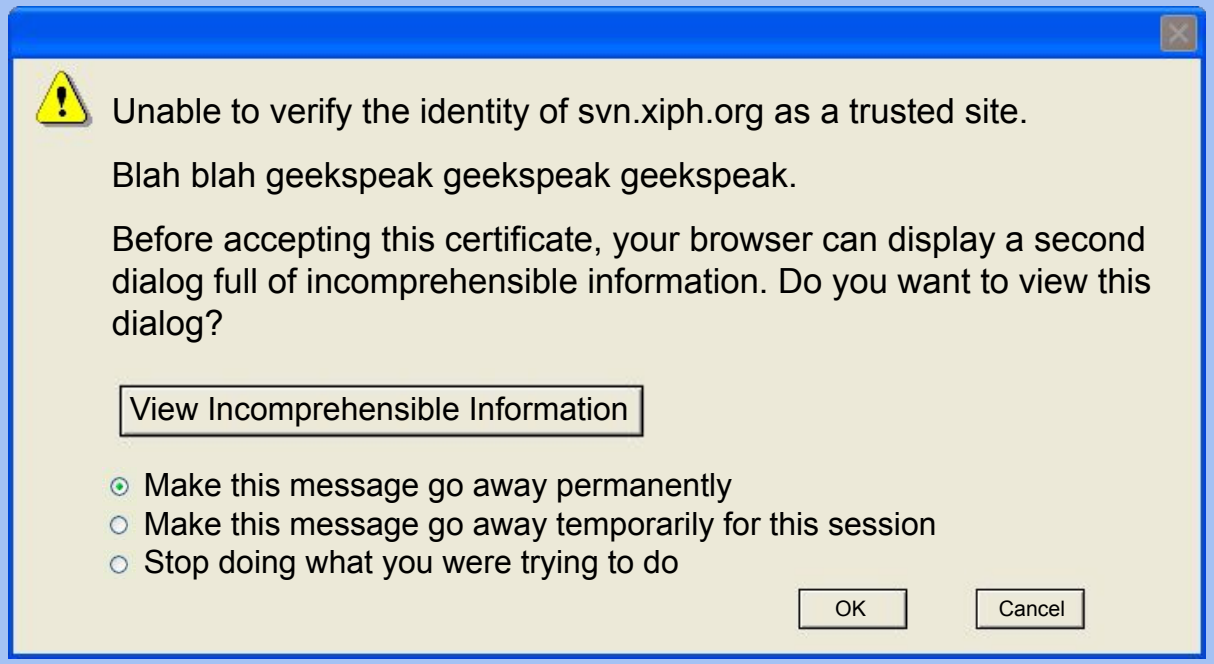
Warning Dialogs



Warning Dialogs



Warning Dialogs



The presence of warning dialogs often represent a failure: How is the user supposed to know what to do?

Takeaway: Consider human factors

Security Principle: Consider Human Factors

- It all comes down to people: The users
  - Users like convenience (ease of use)
  - If a security system is unusable, it will be unused
  - Users will find way to subvert security systems if it makes their lives easier
- It all comes down to people: The programmers
  - Programmers make mistakes
  - Programmers use tools that allow them to make mistakes (e.g. C and C++)
- It all comes down to people: Everyone else
  - Social engineering attacks exploit other people's trust and access for personal gain
- Consider the tools presented to users, and make them **fool**-proof



Physical security keys use the fact that humans are trained to safeguard keys

Security is Economics

Textbook Chapter 1.3

Physical Safes

- We want our safes to stop people from breaking in, so let's measure them by how long it takes an expert to break into one:



TL-15 ($3,000)
15 minutes with common tools



TL-30 ($4,500)
30 minutes with common tools



TRTL-30 ($10,000)
30 minutes with common tools and a cutting torch



TXTL-60 (>$50,000)
60 minutes with common tools, a cutting torch, and up to 4 oz of explosives

Takeaway: Security is economics

Security Principle: Security is Economics

- Cost/benefit analyses often appear in security: The expected benefit of your defense should be proportional to the expected cost of attack
  - More security (usually) costs more
  - If the attack costs more than the reward, the attacker probably won't do it
- Example: You don't put a $10 lock on a $1 item…
  - … unless a $1 item can be used to attack something even more valuable
- Example: You have a brand-new, undiscovered attack that will work on anybody's computer. You wouldn't expose it on a random civilian
  - iPhone security vulnerabilities are often sold for ~$1M on the market, so it's probably safe to use an iPhone on a hostile network if you aren't a $1M target

Detect If You Can’t Prevent

Textbook Chapter 1.4

Burglar Alarms

- Security companies are supposed to detect home break-ins
  - Problem: Too many false alarms. Many alarms go unanswered
  - Placing a sign helps deter burglars from entering at risk of being caught…
    - … even if you don't have an alarm installed!
- **Takeway**: Prevent attacks when you can, but detect them if you can't



Security Principle: Detect if You Can’t Prevent

- **Deterrence**: Stop the attack before it happens
- **Prevention**: Stop the attack as it happens
- **Detection**: Learn that there was an attack (after it happened)
  - If you can’t stop the attack from happening, you should at least be able to know that the attack has happened.
- **Response**: Do something about the attack (after it happened)
  - Once you know the attack happened, you should respond
  - Detection without response is pointless!

Response: Mitigation and Recovery

- Assume that bad things will happen! You should plan security in way that lets you to get back to a working state.
- Example: Earthquakes
  - Have resources for 1 week of staying put
  - Have resources to travel 50 miles from my current location
- Example: Ransomware
  - Keep offsite backups!
  - If your computer and house catch on fire, it should be no big deal.





Detection but no Response

- Bitcoin transactions are irreversible. **If you are hacked, you can never recover your Bitcoins.**
  - $68M stolen from NiceHash exchange in December 2017
  - Four multi-million-dollar attacks on Ethereum in July 2018
  - Coinbase: One **detected** theft per day
- **Takeaway:** Prevention is great, but you must not *only* depend on prevention; you must also respond

Bloomberg

Link

Hacked Bitcoin Exchange Says Users May Share $68 Million Loss

Lulu Yilun Chen and Yuji Nakamura — *August 5, 2016*

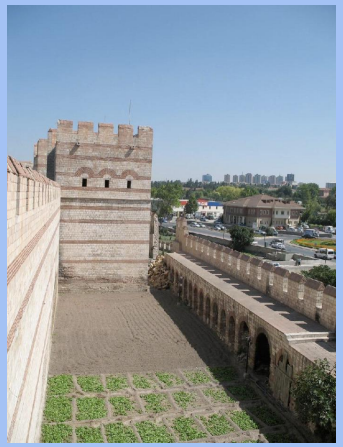
Defense in Depth

Textbook Chapter 1.5

The Theodosian Walls of Constantinople

- The ancient capital of the Byzantine empire had a wall…
  - Well, they had a moat…
  - then a wall…
  - then a depression…
  - … and then an even bigger wall
- It also had towers to rain fire and arrows upon the enemy…
- **Takeaway**: Defense in depth





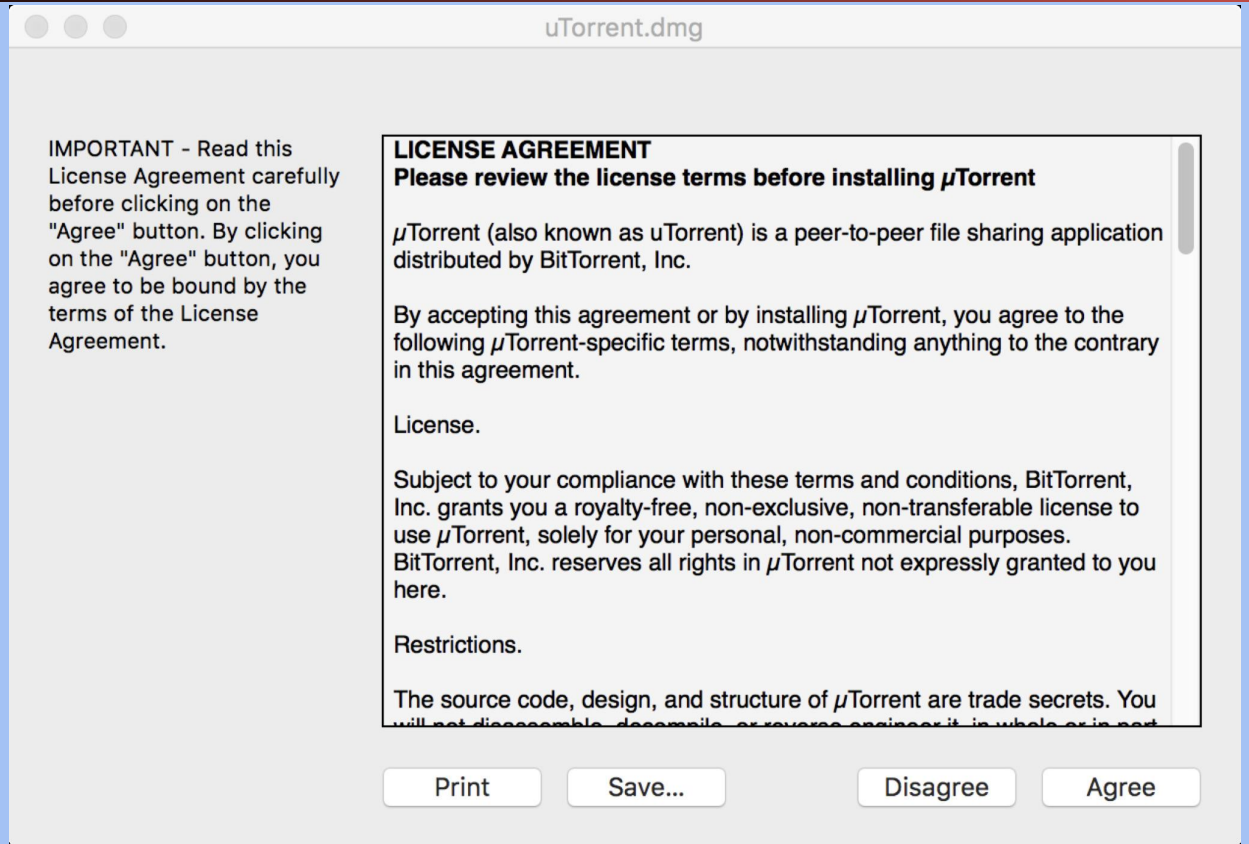
Security Principle: Defense in Depth

- Multiple types of defenses should be layered together
- An attacker should have to breach all defenses to successfully attack a system
- However, consider **security is economics**
  - Defenses are not free.
  - Defenses are often less than the sum of their parts

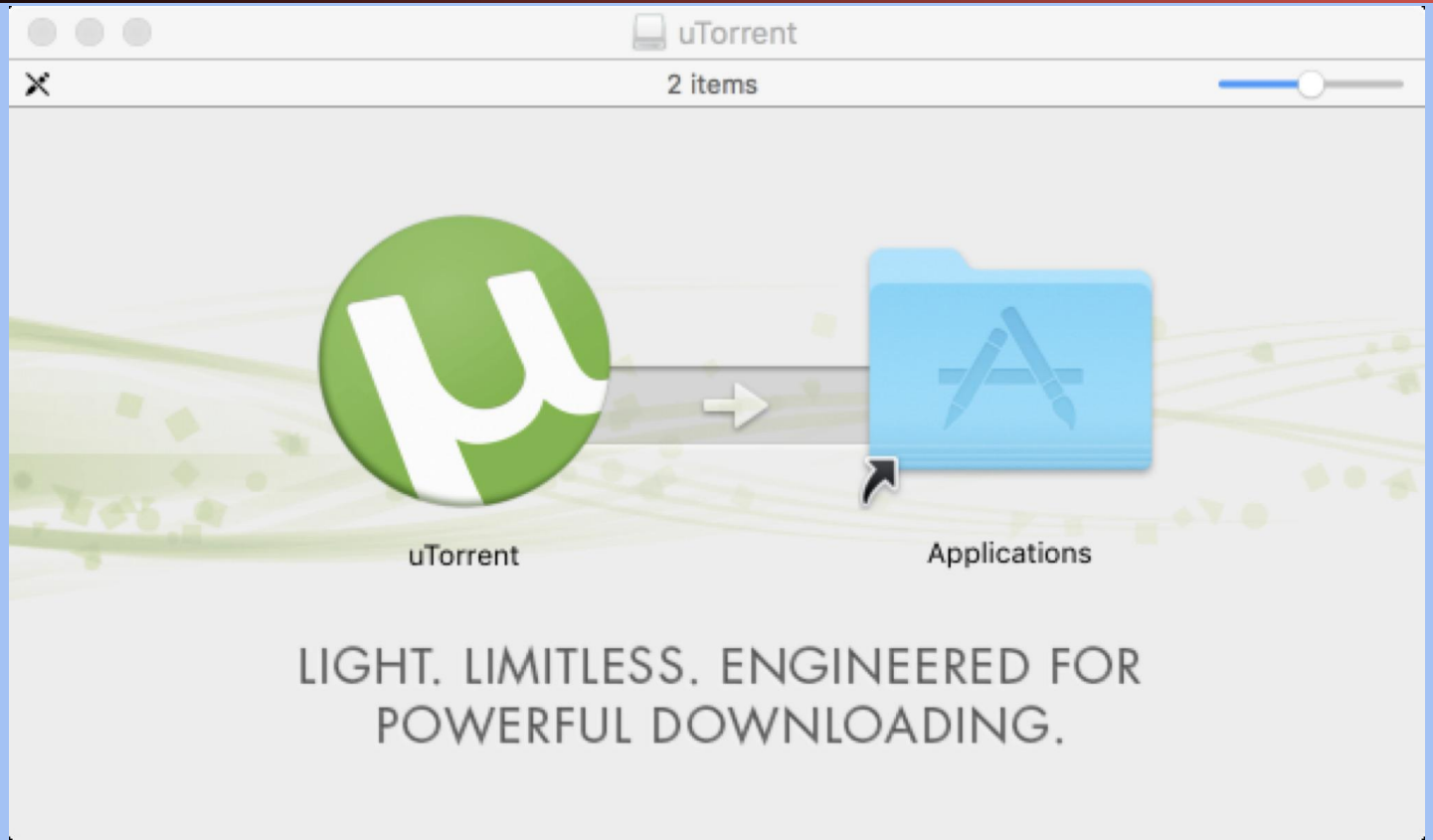
Least Privilege

Textbook Chapter 1.6

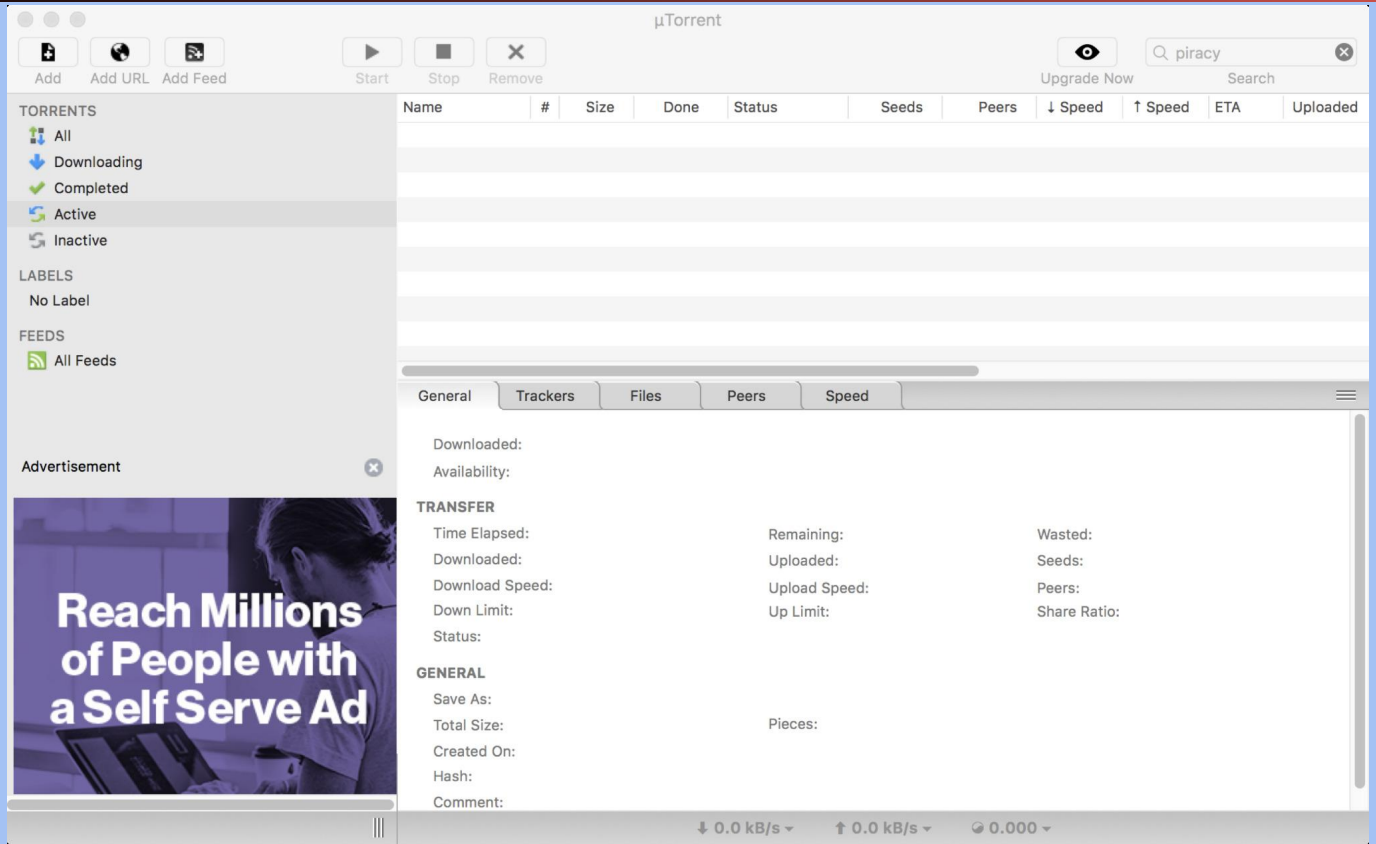
uTorrent


uTorrent.dmg
IMPORTANT - Read this License Agreement carefully before clicking on the "Agree" button. By clicking on the "Agree" button, you agree to be bound by the terms of the License Agreement.
LICENSE AGREEMENT
Please review the license terms before installing µTorrent
µTorrent (also known as uTorrent) is a peer-to-peer file sharing application distributed by BitTorrent, Inc.
By accepting this agreement or by installing µTorrent, you agree to the following µTorrent-specific terms, notwithstanding anything to the contrary in this agreement.
License.
Subject to your compliance with these terms and conditions, BitTorrent, Inc. grants you a royalty-free, non-exclusive, non-transferable license to use µTorrent, solely for your personal, non-commercial purposes. BitTorrent, Inc. reserves all rights in µTorrent not expressly granted to you here.
Restrictions.
The source code, design, and structure of µTorrent are trade secrets. You
Print
Save...
Disagree
Agree

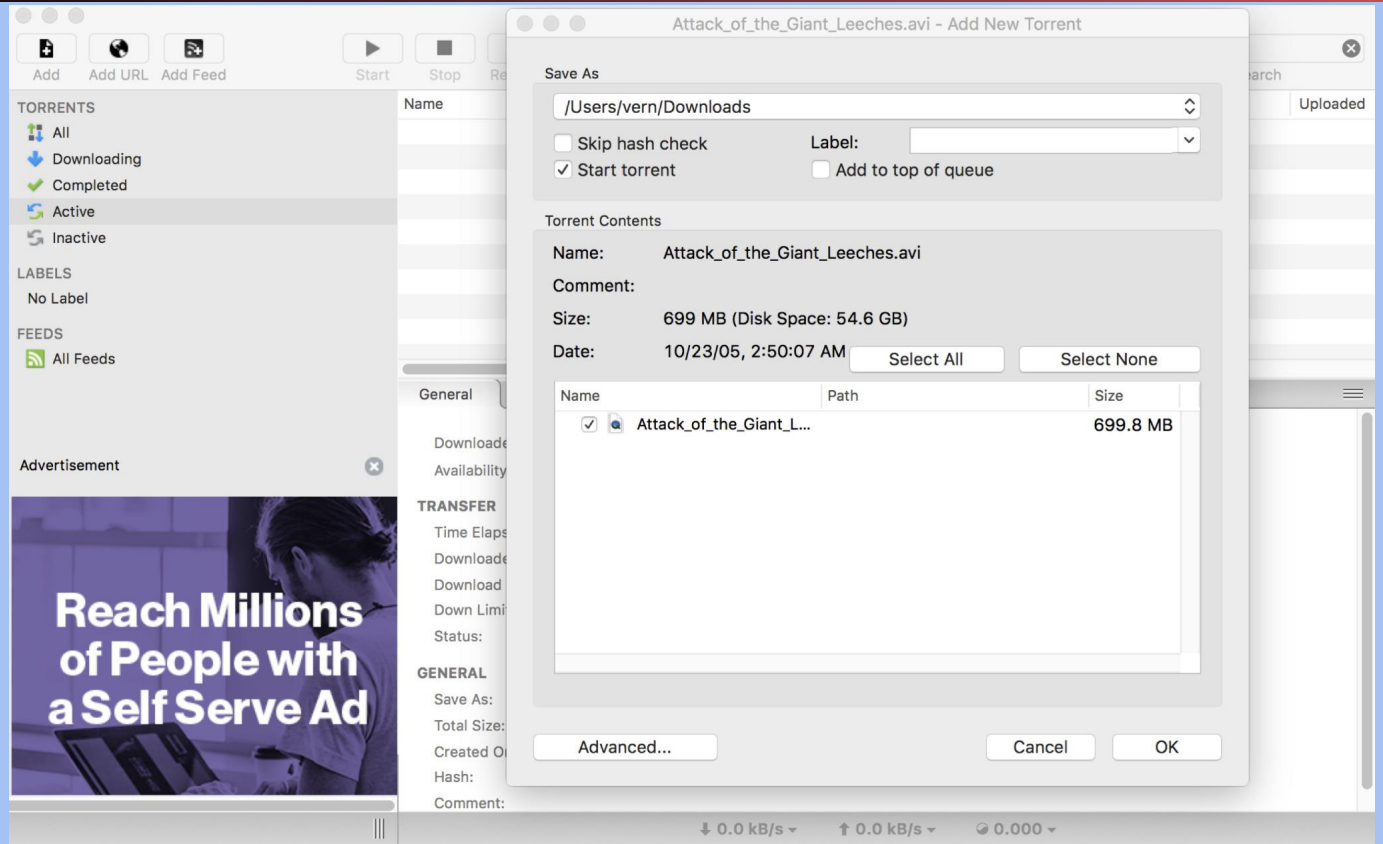
uTorrent


uTorrent
2 items
uTorrent
Applications
LIGHT. LIMITLESS. ENGINEERED FOR
POWERFUL DOWNLOADING.

uTorrent

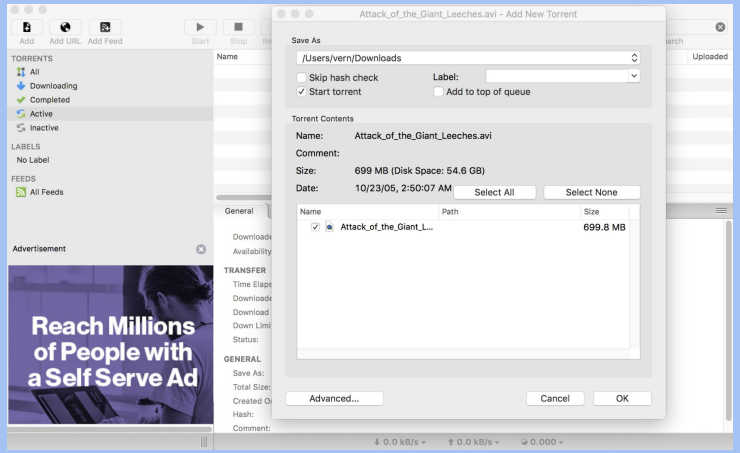

µTorrent
Add
Add URL
Add Feed
Start
Stop
Remove
Upgrade Now
piracy
Search
TORRENTS
All
Downloading
Completed
Active
Inactive
LABELS
No Label
FEEDS
All Feeds
Name
#
Size
Done
Status
Seeds
Peers
↓ Speed
↑ Speed
ETA
Uploaded
General
Trackers
Files
Peers
Speed
Downloaded:
Availability:
TRANSFER
Time Elapsed:
Remaining:
Wasted:
Downloaded:
Uploaded:
Seeds:
Download Speed:
Upload Speed:
Peers:
Down Limit:
Up Limit:
Share Ratio:
Status:
GENERAL
Save As:
Total Size:
Pieces:
Created On:
Hash:
Comment:
Advertisement
Reach Millions of People with a Self Serve Ad
0.0 kB/s
0.0 kB/s
0.000

uTorrent


Add
Add URL
Add Feed
Start
Stop
TORRENTS
All
Downloading
Completed
Active
Inactive
LABELS
No Label
FEEDS
All Feeds
Advertisement
Reach Millions of People with a Self Serve Ad
Name
Uploaded
General
TRANSFER
GENERAL
Save As:
Total Size:
Hash:
Comment:
Attack_of_the_Giant_Leeches.avi - Add New Torrent
Save As
/Users/vern/Downloads
Skip hash check
Start torrent
Label:
Add to top of queue
Torrent Contents
Name: Attack_of_the_Giant_Leeches.avi
Comment:
Size: 699 MB (Disk Space: 54.6 GB)
Date: 10/23/05, 2:50:07 AM
Select All
Select None
Name
Path
Size
Attack_of_the_Giant_L...
699.8 MB
Advanced...
Cancel
OK
0.0 kB/s
0.0 kB/s
0.000

uTorrent

- What was this program able to do?
  - Leak your files
  - Delete your files
  - Send spam
  - Run another malicious program
- What does this program need to be able to do?
  - Access the screen
  - Manage some files (but not all files)
  - Make some Internet connections (but not all Internet connections)
- **Takeaway**: Least privilege



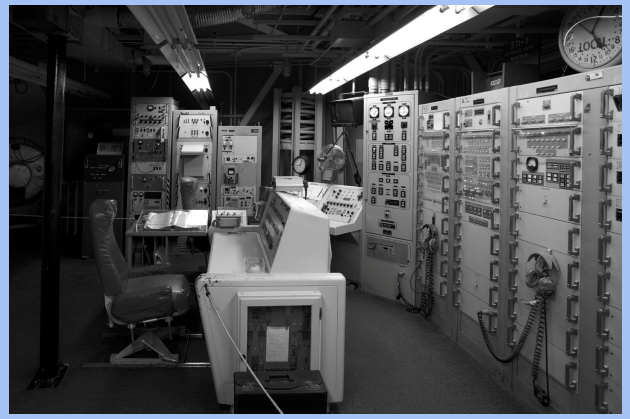
Security Principle: Least Privilege

- Consider what permissions a entity or program *needs* to be able to do its job correctly
  - If you grant unnecessary permissions, a malicious or hacked program could use those permissions against you

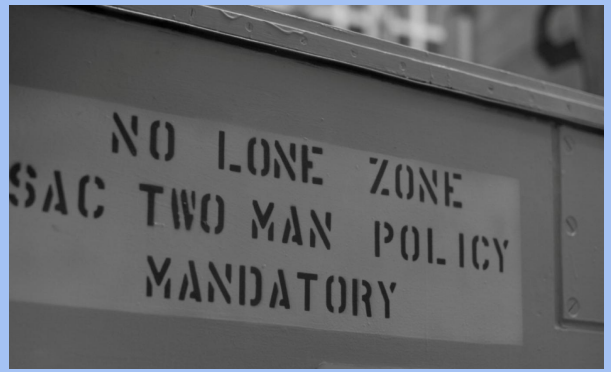
Separation of Responsibility

Textbook Chapter 1.7

Welcome to a Nuclear Bunker









Security Principle: Separation of Responsibility

- If you need to have a privilege, consider requiring multiple parties to work together (collude) to exercise it
  - It's much more likely for a single party to be malicious than for all multiple parties to be malicious and collude with one another

Ensure Complete Mediation

Textbook Chapter 1.8 & 1.13

Spot the Issue



Security Principle: Ensure Complete Mediation

- Ensure that every access point is monitored and protected
- **Reference monitor**: Single point through which all access must occur
  - Example: A network firewall, airport security, the doors to the dorms
- Desired properties of reference monitors:
  - Correctness
  - Completeness (can't be bypassed)
  - Security (can't be tampered with)
  - Should be part of the TCB



The cars drove around the barrier

Time-of-Check to Time-of-Use

- A common failure of ensuring complete mediation involving race conditions
- Consider the following code:

```
procedure withdrawal(w)
    // contact central server to get balance
    1. let b := balance

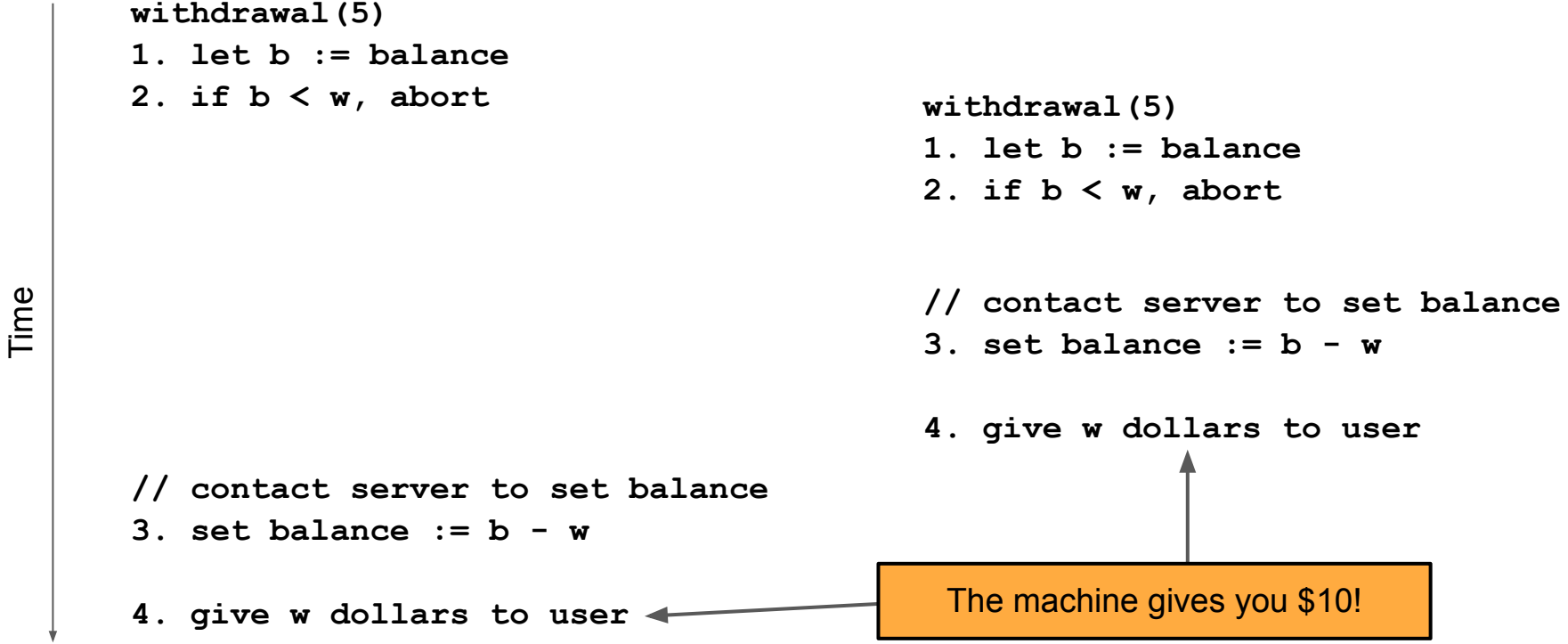
    2. if b < w, abort

    // contact server to set balance
    3. set balance := b - w

    4. give w dollars to user
```

Suppose you have $5 in your account. How can you trick this system into giving you more than $5?

Time-of-Check to Time-of-Use



Don’t Rely on Security Through Obscurity

Textbook Chapter 1.9

Accident on Motorway



Here's a highway sign.



Here's the hidden computer inside the sign.



Here's the control panel. Most signs use the default password, **DOTS**.

Caution! Zombies Ahead!!!



Note: Do not **ever** do this. Yes, some former CS 161 students did it once.

Trapped in Sign Factory! Send Help!





Takeaway: Shannon's maxim/Don't rely on security through obscurity

Security Principle: Shannon's Maxim

- **Shannon's maxim**: "The enemy knows the system"
- You should never rely on obscurity as part of your security. Always assume that the attacker knows every detail about the system you are working with (algorithms, hardware, defenses, etc.).



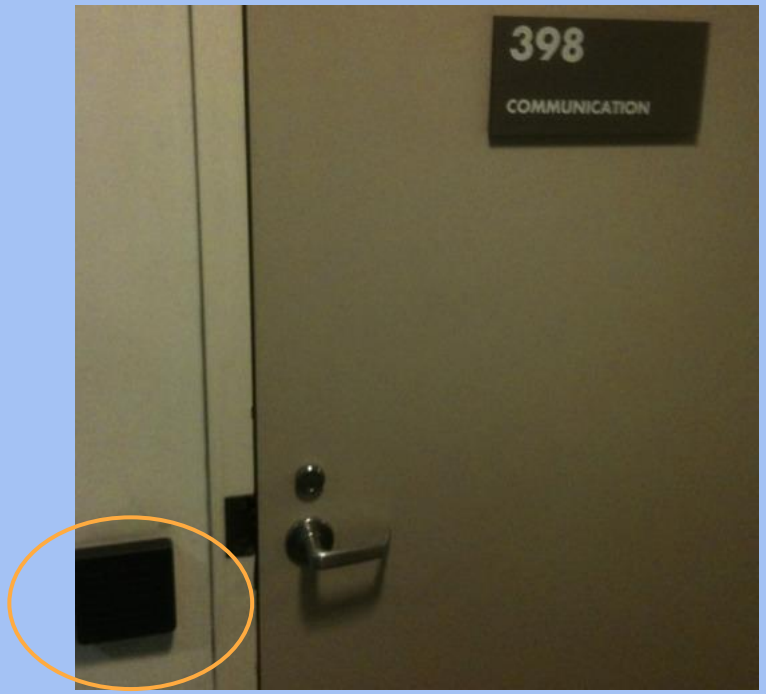
Assume the attacker knows where the "secret" control panel is located, and has read the manual with instructions on resetting the password.

Use Fail-Safe Defaults

Textbook Chapter 1.10

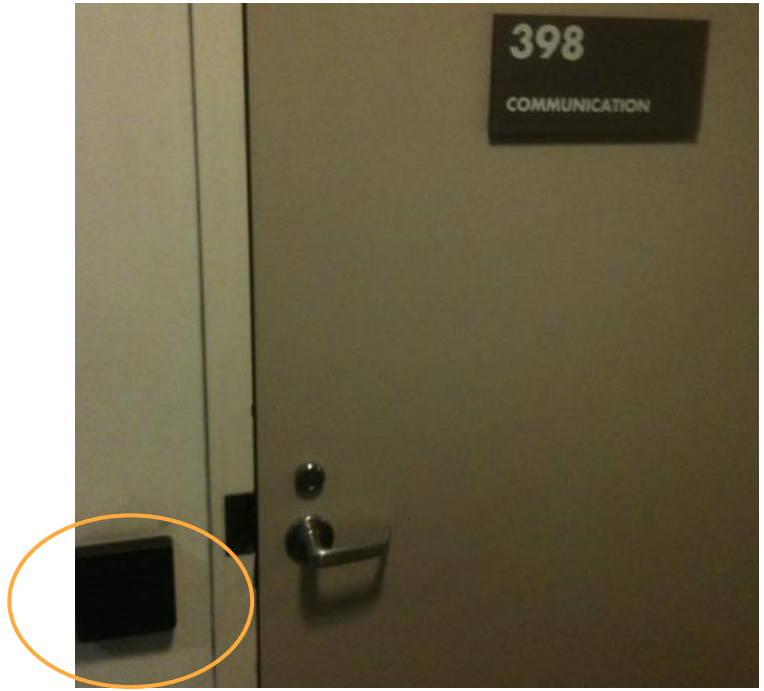
Soda Hall

- Rooms in Berkeley's Soda Hall are guarded by electronic card keys
- What do you do if the power goes out?
  - **Fail closed**: No one can get in if the power is out
  - **Fail open**: Anyone can get in if the power goes out
- What's the best option to choose for closets with expensive equipment? What about emergency exit doors?
- **Takeaway**: Use fail-safe defaults



Security Principle: Use Fail-Safe Defaults

- Choose default settings that “fail safe,” balancing security with usability when a system goes down
  - This can be hard to determine



Design in Security from the Start

Textbook Chapter 1.11

Security Principle: Design in Security from the Start

- When building a new system, include security as part of the design considerations rather than patching it after the fact
  - A lot of systems today were not designed with security from the start, resulting in patches that don't fully fix the problem!
- Keep these security principles in mind whenever you write code!

Security Principles: Summary

- **Know your threat model**: Understand your attacker and their resources and motivation
- **Consider human factors**: If your system is unusable, it will be unused
- **Security is economics**: Balance the expected cost of security with the expected benefit
- **Detect if you can't prevent**: Security requires not just preventing attacks but detecting and responding to them
- **Defense in depth**: Layer multiple types of defenses
- **Least privilege**: Only grant privileges that are needed for correct functioning, and no more
- **Separation of responsibility**: Consider requiring multiple parties to work together to exercise a privilege
- **Ensure complete mediation**: All access must be monitored and protected, unbypassable
- **Shannon's maxim**: The enemy knows the system
- **Use fail-safe defaults**: Construct systems that fail in a safe state, balancing security and usability.
- **Design in security from the start**: Consider all of these security principles when designing a new system, rather than patching it afterwards